

VindobonaPay GmbH — Control Mapping Matrix

ISO/IEC 27001:2022 ↔ NIS2 (EU 2022/2555) ↔ DORA (EU 2022/2554) ↔ NIST CSF 2.0 | Version 1.0 | Fictional company for educational purposes

#	Security domain	ISO/IEC 27001:2022 Annex A	NIS2 Directive	DORA Regulation	NIST CSF 2.0	Coverage	What the ISMS covers — and what the regulations add
D-01	Governance and management accountability	A.5.1, A.5.2, A.5.4, A.5.36 (+ Clauses 5, 9.3)	Art. 20; Art. 21(2)(f)	Art. 5, Art. 6(4)(5)(6)	GV.RR, GV.PO, GV.OV	ISMS + additions	The ISMS provides policies, roles and management review. Both regulations go further: the management body is personally accountable and must receive cybersecurity training, and DORA requires the ICT risk framework to be reviewed yearly and audited internally.
D-02	Information security risk management	Clause 6.1; A.5.9, A.5.31	Art. 21(2)(a)	Art. 6, Art. 8	GV.RM, ID.RA	ISMS + additions	Risk assessment methodology and risk register (Deliverable 02) satisfy the core requirement. DORA expects an ICT-specific risk management framework with a documented digital operational resilience strategy.
D-03	Asset management and information classification	A.5.9, A.5.10, A.5.12, A.5.13	Art. 21(2)(i)	Art. 8	ID.AM	Covered by ISMS	Asset inventory and classification are addressed by the ISMS. DORA adds the mapping of assets supporting critical or important functions.
D-04	Identity, access control and authentication	A.5.15, A.5.16, A.5.17, A.5.18, A.8.2, A.8.3, A.8.5	Art. 21(2)(i), 21(2)(j)	Art. 9	PR.AA	Covered by ISMS	Annex A covers identity lifecycle, access rights and authentication. NIS2 names multi-factor authentication explicitly, which the ISMS already implements.
D-05	Human resources security and awareness	A.6.1 to A.6.6, A.6.8	Art. 20(2); Art. 21(2)(g)	Art. 13(6)	PR.AT	ISMS + additions	Screening, contracts, training and disciplinary process are covered. The specific obligation to train the management body comes from the regulations, not from Annex A.
D-06	Cryptography and data protection	A.8.24, A.8.10, A.8.11, A.8.12, A.5.34	Art. 21(2)(h)	Art. 9	PR.DS	Covered by ISMS	Encryption, key management and data protection are addressed. GDPR obligations run in parallel for personal data.
D-07	Physical and environmental security	A.7.1 to A.7.14	Art. 21(2)(i)	Art. 9(4)(d)	PR.IR, PR.PS	Covered by ISMS	Annex A is more detailed than either regulation in this area. For a cloud-first company the on-premises footprint is limited.
D-08	Operations, configuration and vulnerability management	A.8.7, A.8.8, A.8.9, A.8.19, A.8.32	Art. 21(2)(e)	Art. 7, Art. 9	PR.PS	Covered by ISMS	Malware protection, patching, hardening and change management are covered by the ISMS.
D-09	Network and communications security	A.8.20, A.8.21, A.8.22, A.8.23	Art. 21(2)(i), 21(2)(j)	Art. 9	PR.IR	Covered by ISMS	Network segmentation, filtering and secure services are addressed. NIS2 also refers to secured emergency communications.
D-10	Logging, monitoring and detection	A.8.15, A.8.16, A.8.17	Art. 21(2)(b)	Art. 10	DE.CM, DE.AE	ISMS + additions	The ISMS requires logging and monitoring. DORA is more prescriptive on detection mechanisms, alert thresholds and the resources dedicated to monitoring anomalous activity.
D-11	Incident management and response	A.5.24, A.5.25, A.5.26, A.5.27, A.5.28	Art. 21(2)(b); Art. 23	Art. 17, Art. 18	RS.MA, RS.AN, RS.MI	ISMS + additions	Incident handling is covered. DORA adds a defined classification of incidents against regulatory criteria, which determines what must be reported.
D-12	Business continuity, backup and recovery	A.5.29, A.5.30, A.8.13, A.8.14	Art. 21(2)(c)	Art. 11, Art. 12	RC.RP, RC.CO, PR.IR	ISMS + additions	Backup and continuity are addressed. DORA requires ICT business continuity policies, recovery objectives and periodic testing of recovery plans as a regulatory obligation.
D-13	Supplier and ICT third-party risk	A.5.19, A.5.20, A.5.21, A.5.22, A.5.23	Art. 21(2)(d); Art. 22	Art. 28, 29, 30 (Art. 31-44 oversight)	GV.SC	Beyond ISMS	Annex A requires supplier security management, but DORA sets specific obligations: a register of contractual arrangements, mandatory contractual provisions, concentration risk assessment and exit strategies for critical functions.
D-14	Secure development and application security	A.8.25, A.8.26, A.8.27, A.8.28, A.8.29, A.8.31, A.8.33	Art. 21(2)(e)	Art. 8, Art. 9	PR.PS	Covered by ISMS	Secure SDLC, code review and testing are covered by the ISMS. Relevant for VindobonaPay because all development is in-house.
D-15	Digital operational resilience testing	A.8.29 (partial), A.5.30 (partial)	Art. 21(2)(f)	Art. 24, 25, 26, 27	ID.IM	Beyond ISMS	The ISMS tests controls through audits and penetration testing. DORA requires a formal testing programme, and threat-led penetration testing for entities identified by the authorities.
D-16	Regulatory reporting and contact with authorities	A.5.5, A.5.31, A.5.33	Art. 23 (24h / 72h / 1 month)	Art. 19, 20, 21, 23	RS.CO, GV.OC	Beyond ISMS	Annex A requires contact with authorities and a legal register, but not the reporting workflow itself: deadlines, templates and recipients are set by the regulations.

Coverage:

Covered by ISMS

ISMS + additions

Beyond ISMS

Note: DORA applies to VindobonaPay as a financial entity. Under Article 1(2) of DORA, its ICT risk management, incident reporting, resilience testing and third-party provisions apply instead of the corresponding NIS2 obligations.

Sources: EUR-Lex (Directive (EU) 2022/2555; Regulation (EU) 2022/2554), NIST CSF 2.0. No standard or regulatory text is reproduced: references and descriptions are written in my own words.

Obligations not satisfied by Annex A alone

Regulatory requirements that an ISO/IEC 27001 ISMS supports but does not automatically fulfil.

#	Obligation	Source	Why an ISO/IEC 27001 ISMS is not enough on its own	Addressed in
G-01	Register of information on contractual arrangements with ICT providers	DORA Art. 28(3)	Annex A requires supplier records, not a structured register in a regulatory format submitted to the authority.	Deliverable 05
G-02	Mandatory contractual provisions in ICT contracts	DORA Art. 30	A.5.20 requires security clauses in agreements, but not the specific provisions DORA lists (access, audit, termination, subcontracting).	Deliverable 05
G-03	Assessment of ICT concentration risk	DORA Art. 29	Not addressed by Annex A: it is a portfolio-level analysis of dependency on a small number of providers.	Deliverable 05
G-04	Exit strategies for ICT services supporting critical functions	DORA Art. 28(8)	A.5.23 mentions cloud exit planning; DORA makes it an obligation with defined content for critical functions.	Deliverable 05
G-05	Digital operational resilience testing programme	DORA Art. 24, 25	Annex A requires security testing in development; DORA requires a documented programme covering systems supporting critical functions, at least yearly.	Deliverable 05
G-06	Threat-led penetration testing (TLPT)	DORA Art. 26, 27	No equivalent in Annex A. Applies to entities identified by the competent authority, with requirements for testers.	Deliverable 05
G-07	Classification of ICT incidents against regulatory criteria	DORA Art. 18	A.5.25 requires triage criteria set by the organization; DORA sets the criteria that determine whether an incident is major.	Deliverable 05
G-08	Reporting of major incidents (initial, intermediate, final report)	DORA Art. 19	Annex A does not define reporting deadlines or templates. Deadlines are set by the regulation and its technical standards.	Deliverable 05
G-09	Incident notification timeline (early warning 24h, notification 72h, final report 1 month)	NIS2 Art. 23	Same point for the NIS2 regime. For financial entities DORA applies instead, but the general framework is relevant context.	Deliverable 04
G-10	Management body accountability and cybersecurity training	NIS2 Art. 20; DORA Art. 5(2), 13(6)	A.5.4 requires management support; the regulations make the management body personally accountable and require training.	Deliverable 04 / 05
G-11	Yearly review and internal audit of the ICT risk management framework	DORA Art. 6(5), 6(6)	The ISMS requires internal audit (Clause 9.2), but DORA requires it specifically for the ICT risk framework, by auditors with ICT expertise.	Deliverable 05
G-12	Crisis communication plans	DORA Art. 14	Annex A covers incident communication indirectly; DORA requires plans for responsible disclosure to clients, counterparts and the public.	Deliverable 05

Mapping Summary — VindobonaPay GmbH

Values calculated automatically from the Mapping sheet.

Security domains mapped	16
BY COVERAGE	
Covered by ISMS	7
ISMS + additions	6
Beyond ISMS	3
Obligations beyond Annex A	12

The three 'Beyond ISMS' domains — third-party risk, resilience testing and regulatory reporting — are exactly the DORA-specific areas covered in Deliverable 05.